

IT Security Basics

Introduction to IT Security

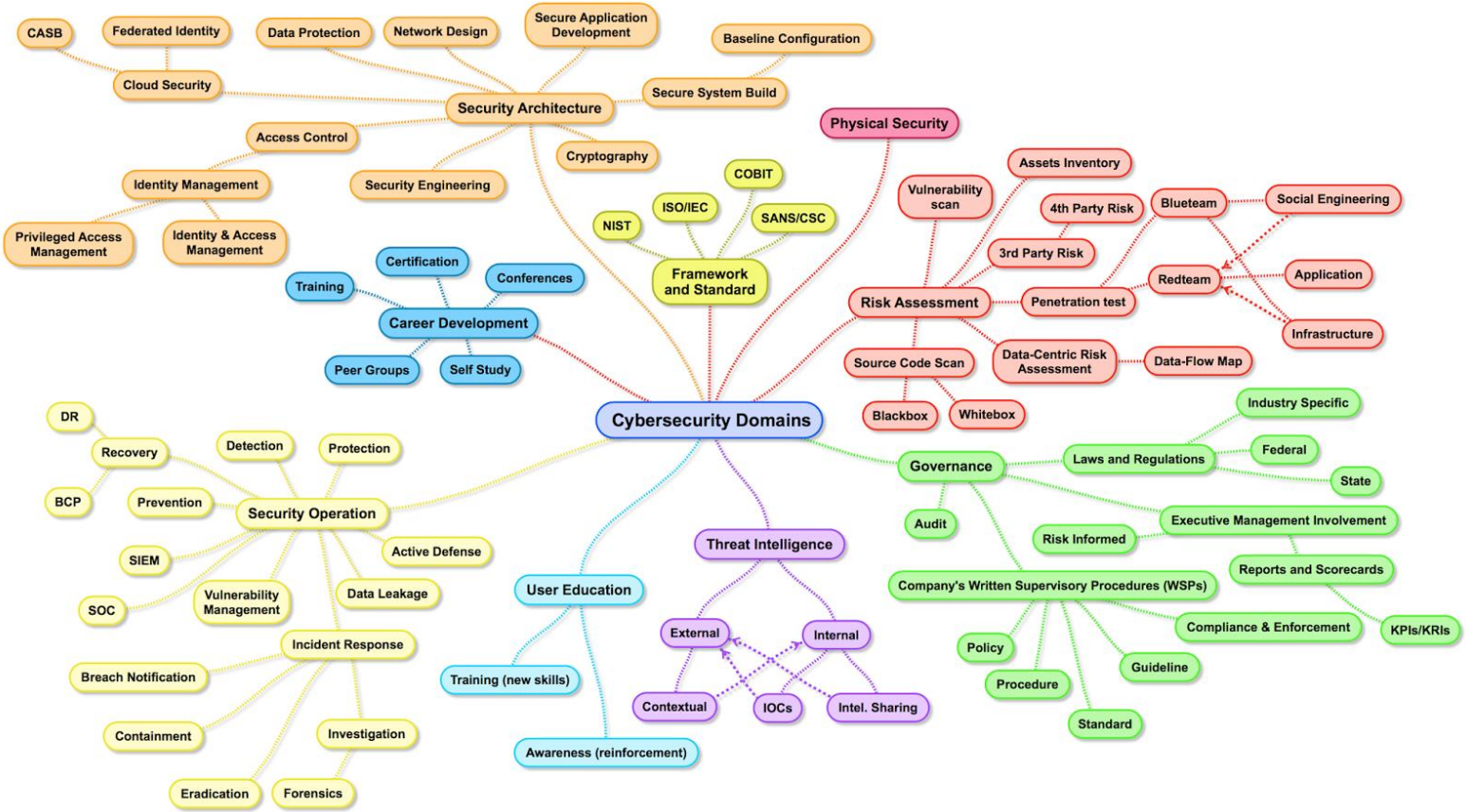
What do you associate with the terms „IT Security“ or „Cyber Securtiy“?

What is Information Security (aka IT-Security) in general?

- All activities and product deployment to prevent unauthorized access, modification and deletion of information.

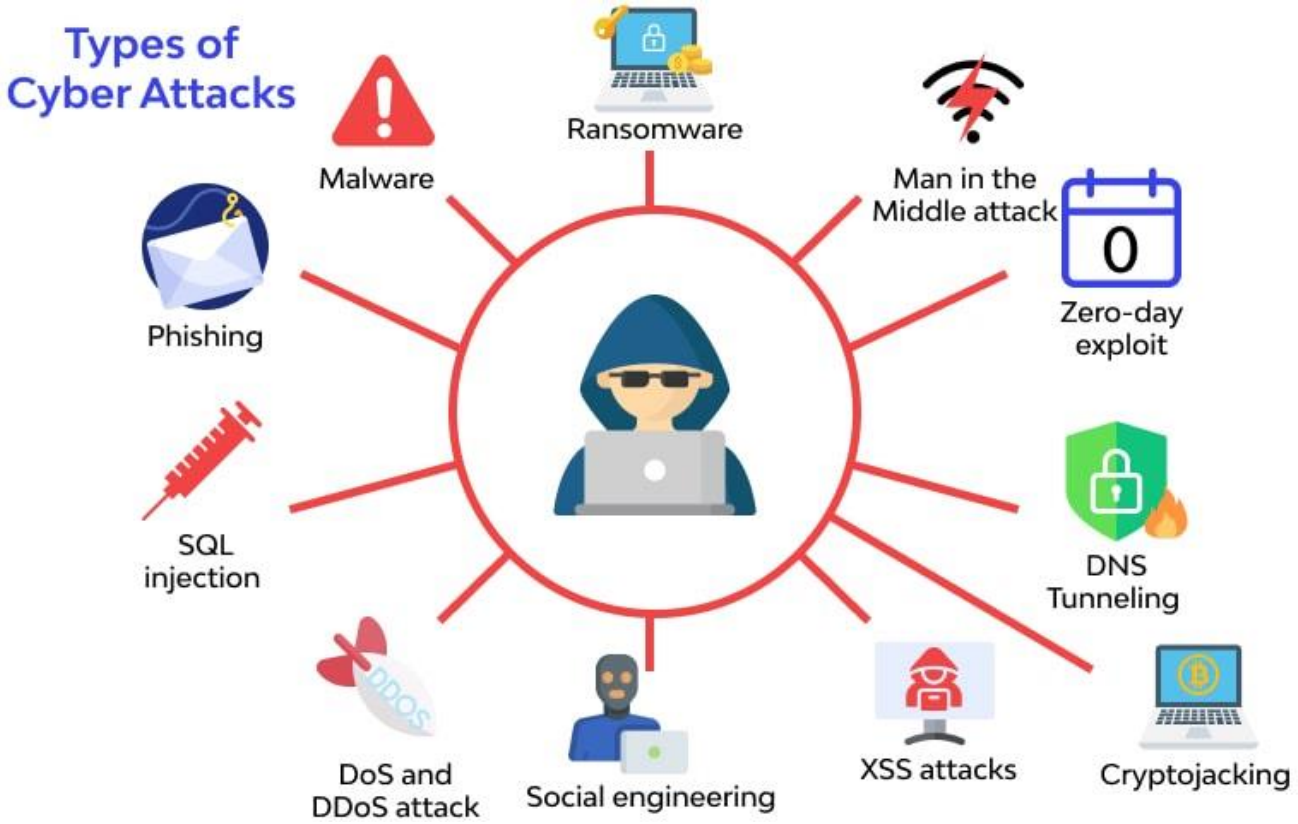
- Protecting the company's most valuable assets from attack, malicious behavior, and human error, both internal and external

What is Information Security (aka IT-Security)?



Source https://2.bp.blogspot.com/-OgGmvicsBPk/WNEl5_R2xpI/AAAAAAAAfvQ/gFEk1qkhaT805_R4MBzcc7MtjaNm2-YRACLcB/s1600/cybersecurity%2Bdomains%2Bv2-0%2Bhenry%2Bjiang.png

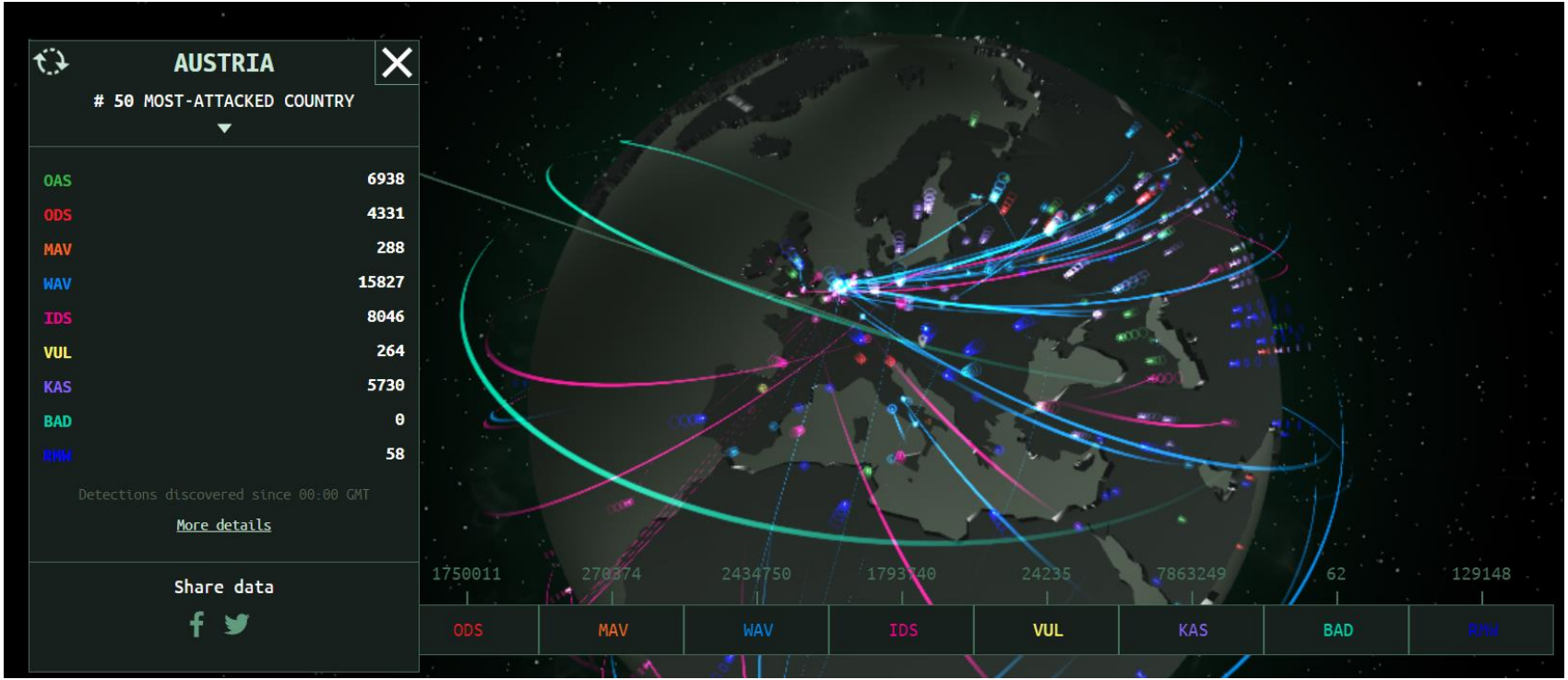
Why Cyber Security?



Source: https://www.wallarm.com/what/what-is-a-cyber-attack

Why Cyber Security?

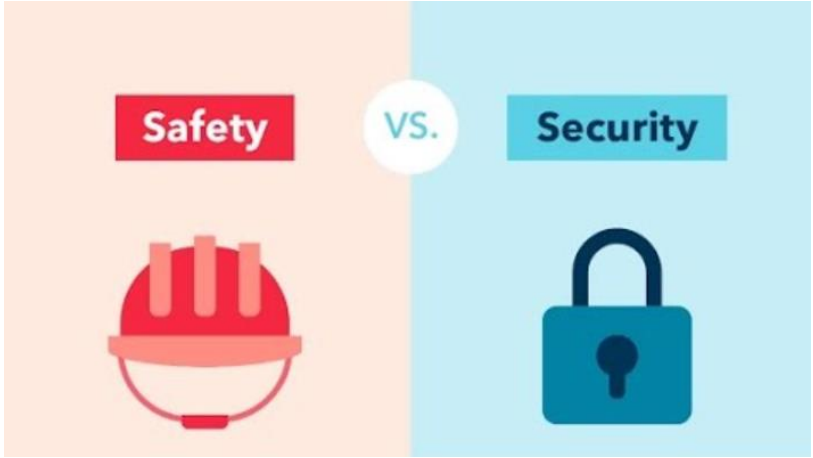
- https://cybermap.kaspersky.com/



What is the difference between „IT Security“ and „safety“?

Security vs. Safety

- Safety:
  - Protection of people and environment
  - Protection against accidents
  - Examples:
    - Helmets for employees at a construction site
    - Seat belts in the car
    - Emergency stop switch for machines
- IT Security:
  - Protection of data, networks and computersystems
  - Examples
    - Firewalls
    - Encryption
    - Access Control



Source: https://i.ytimg.com/vi/MBfTjwxOkqY/hqdefault.jpg

Terms of information security

- **Attack**
  - An attack on systems security. A distinction is made between different attacks, an attack is always directed at one or more protection targets
- **Countermeasure**
  - Activities or systems that reduce or even prevent the risk of an attack or the effects of such an attack
- **Risk**
  - Probability of occurrence and expected level of damage of a successful attack

Terms of information security

- **Security policy**
  - Rules and procedures to reduce risks

- **Vulnerability**
  - Vulnerability, in hardware, software, network, processes, policies, etc. or the lack of protective measures that could be exploited by an attacker.

- **Threat**
  - The general risk that a vulnerability could be exploited

Protection Goals

- In order to secure data and systems, specifications, the protection goals are defined.

- The 3 most basic are referred to as the "CIA Triad"...
  - Confidentiality
  - Integrity
  - Availability
- Further protection goals are
  - Non-repudiation
  - Authenticity of information



Source: https://securitymadesimple.org/cybersecurity-blog/what-are-the-3-principles-of-information-security/

Protection goals according to ISO 27000:2020

- **Confidentiality**
  - Characteristic that information is not made available or disclosed to unauthorized persons, entities or processes.

- **Availability**
  - The property of being accessible and usable when an authorized entity has a need to do so

- **Integrity**
  - Property of correctness and completeness of data

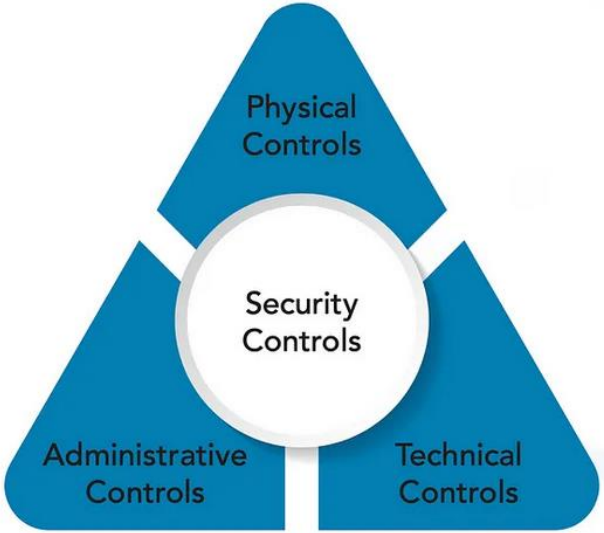
Protection goals according to ISO 27000:2020

- **Non-repudiation**
  - Ability to prove the occurrence of an alleged event or act together with its causal entities.
  - In other / easier words: always know who did what

- **Authenticity**
  - Property that an entity is what / who it claims to be

Division of areas for the protection of data and systems

- **Physical security**
  - Threats and measures regarding access control, power supply, protection against fire and water damage, etc.



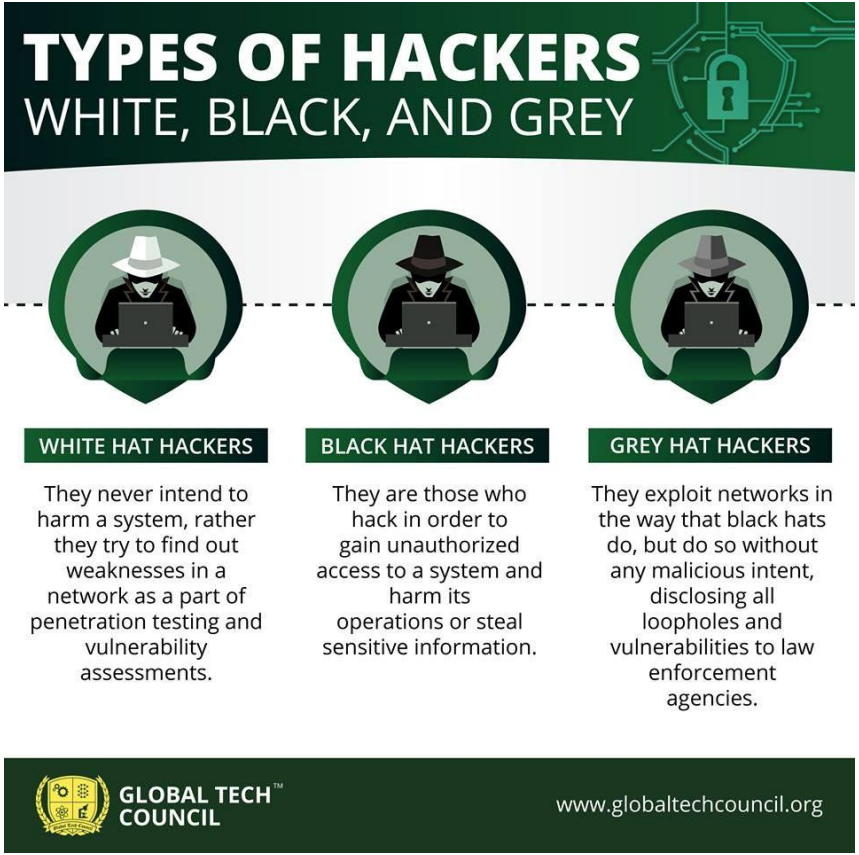
- **Technical security**
  - Protection of actual systems, malware prevention, encryption, network protection, etc.

- **Organizational security**
  - Organizational measures for secure procedures, processes, definition of responsibilities, policies, etc.

Source: https://ionut-vasile.medium.com/physical-technical-administrative-controls-3d605a2dc0f8

What types of hacker do you know?

Types of hackers



Source: https://i.pinimg.com/originals/97/09/82/970982ba6b897ad2d74dd10d9da2932f.jpg

When you are an attacker, what steps would you do to get into a system? How would you start?

NSIT Cybersecurity Framework

- NIST established the Cybersecurity Framework
  - Defines 5 pillars of a successful cybersecurity program
  - https://www.nist.gov/cyberframework

- There are different methodologies to establish security programs in companies e.g.
  BSI IT-Grundschutz



Source: https://www.nist.gov/news-events/news/2018/04/nist-releases-version-11-its-popular-cybersecurity-framework

The 5 pillars of a successful cybersecurity program (NIST)

- **Identify**
  - Data, people, processes, and systems that enable the organization to achieve its business objectives are identified and evaluated according to their relative importance to the business objectives.
- **Protect**
  - Develop and implement appropriate safeguards to protect identified assets.
- **Detect**
  - Develop and implement appropriate activities to identify cybersecurity events that have occurred as quickly as possible.



Source: https://www.nist.gov/news-events/news/2018/04/nist-releases-version-11-its-popular-cybersecurity-framework

The 5 pillars of a successful cybersecurity program (NIST)

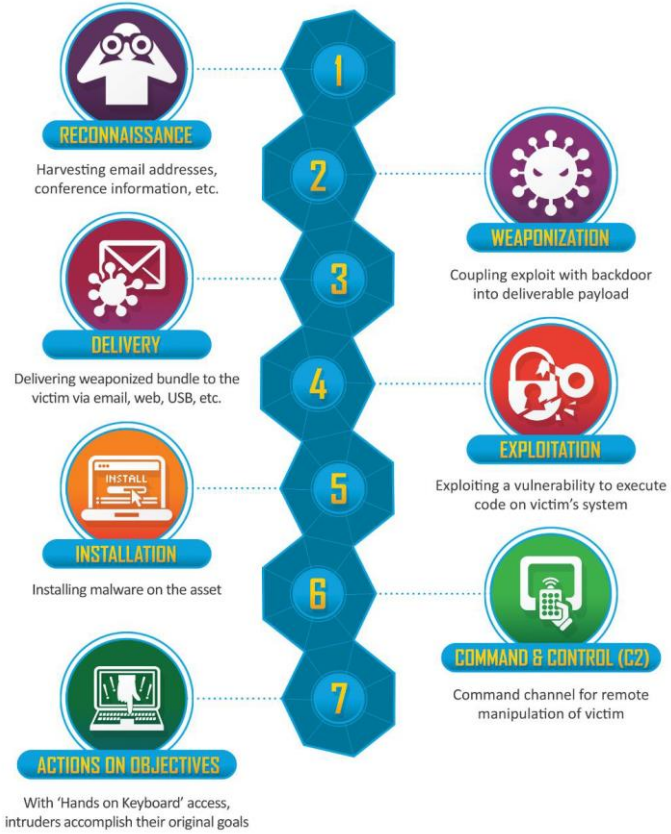
- **Respond**
  - Activities to take appropriate action in relation to an identified security incident are defined and appropriate processes implemented (incident response).

- **Recover**
  - Plans to maintain and restore standard operations are developed and reviewed regularly.



Source: https://www.nist.gov/news-events/news/2018/04/nist-releases-version-11-its-popular-cybersecurity-framework

Cyber Kill Chain



- Developed by Lockheed Martin
- Presents the phases of an attack in a structured way
- In order to be able to defend our systems we need to know how attackers operate.
- There are slightly different „versions“ of the cyber kill chain

Source: https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html

Reconnaissance

- Attackers try to get as much information as possible about their target

- Passive Reconnaissance or Open Source Intelligence Gathering (OSINT)
  - Attacker uses all possible public sources to obtain information
  - E.g. search engines, domain information, social media, job portals, etc.

- Active Reconnaissance
  - Attackers resort to active methods such as port scanning, website scanning, social engineering attacks to elicit employee information, etc.

Weaponization

- Based on the reconnaissance, possible attack vectors are defined

- Attacks are prepared for the attack vectors that appear most likely successful
- Examples:
  - The target uses Microsoft Office → creating Office Macro viruses
  - Planning a phishing attack
  - Planning a social engineering attack, etc.

Delivery

- The planned attacks of the Weaponize phase are carried out
- Examples
  - Attack on the services accessible on the Internet
  - Phishing attack
  - Watering Holw Attack
  - Social engineering attack, etc.

Exploitation

- After delivering the payload, the malicious code is executed to give the attacker an initial foothold in the target network.

- An initial foothold means the attacker usually still has underprivileged access to the system and can execute commands there.

- Examples:
  - Exploiting a vulnerability in a well known service
  - Trojan Dropper

Installation

- The attacker increases his privileges to system rights, downloads malware e.g. Remote Access Tool (RAT) or rootkits

- The attacker thus keeps his access to the system, so that even if the exploited vulnerability is patched, he still has access

Command & Control

- The affected system connects itself to a Command & Control (C&C) server and receives commands from the server.
- The C&C servers are controlled by the attackers

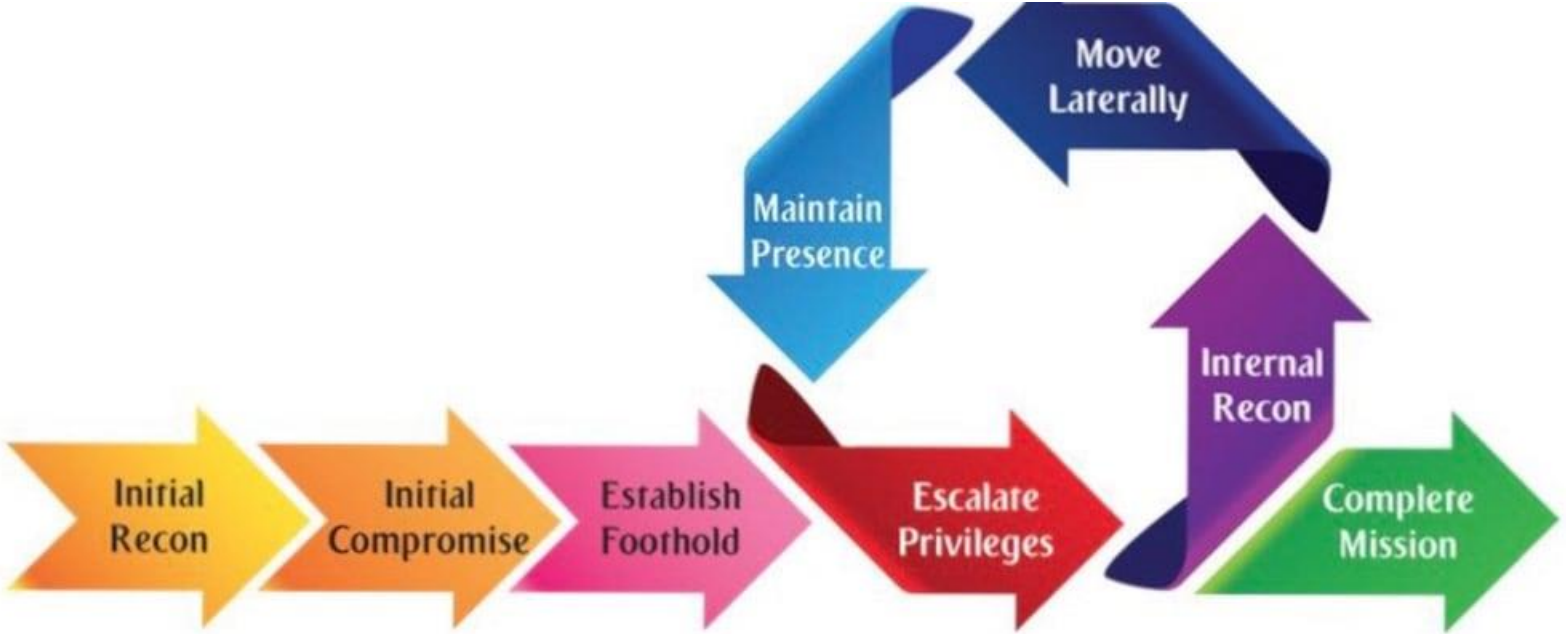
Action

- From the C&C phase, the system is completely in the hands of the attacker,
- The attacker can read out information and attack other systems via the infected system.

Cyber Attack Lifecycle

- The Cyber Kill Chain is not a linear but a cyclical process!
- Attackers only have access to data of the one system that has been taken over.
- Therefore, the attacker will start the cyber kill chain all over again, this time targeting systems within the network
- This is what is called "lateral movement."
- This process is repeated until the attack is detected and repelled or the attacker has reached a "Mission Goal".

Cyber Attack Lifecycle



Source: https://dev.to/0xbanana/30daysofthreads-the-cyber-attack-lifecycle-14i2

MITRE ATT&CK Framework

- Mitre has created a model including an attack matrix for different target systems

- Again, the mindset was, that you have to know the attacks to be able to defend yourself

- Adversarial Tactics, Techniques, and Common Knowledge (ATT&CK)

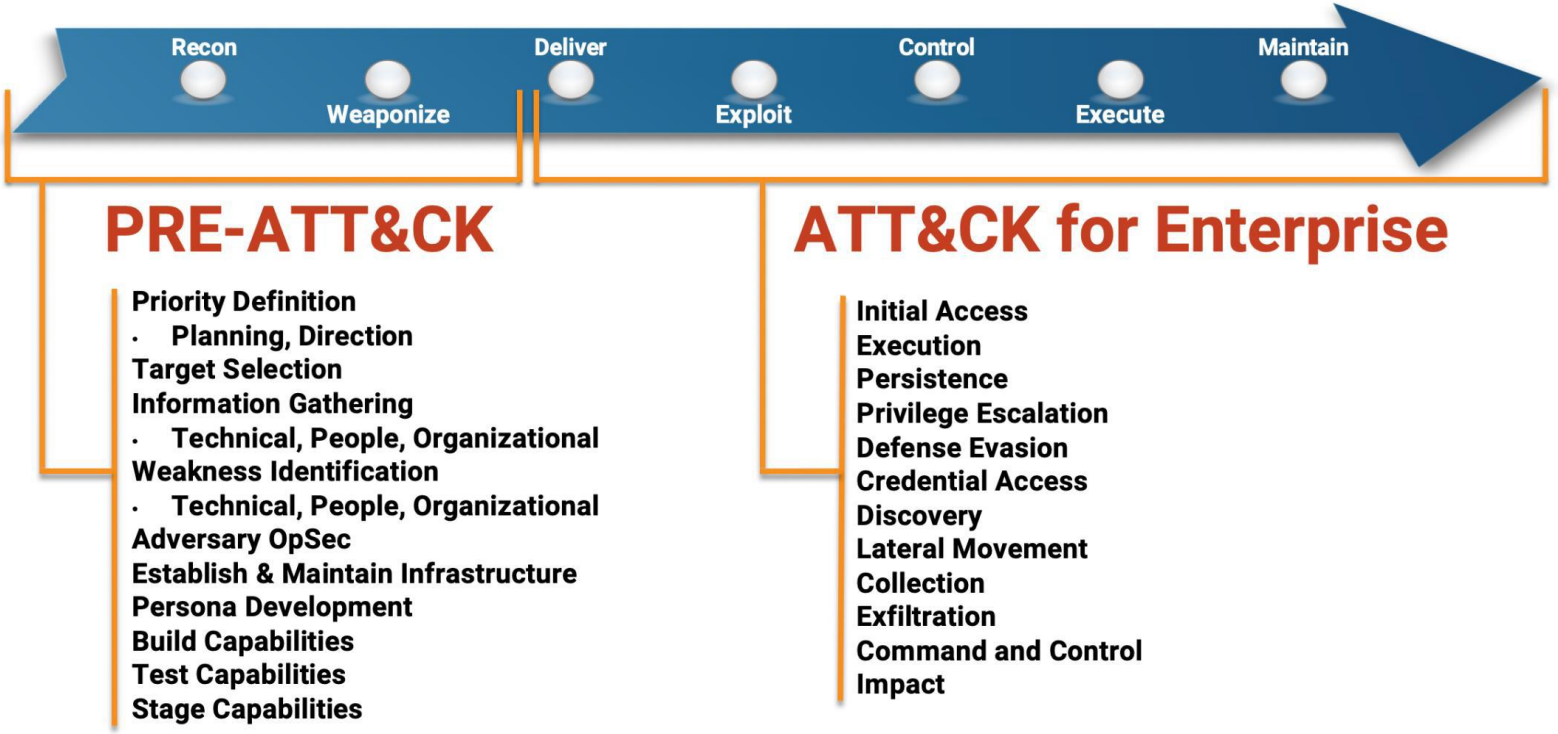
- https://www.mitre.org/sites/default/files/publications/pr-18-0944-11-mitre-attack-design-and-philosophy.pdf

MITRE ATT&CK Matrix

- Since the Cyber Kill Chain is only a high level model, Mitre has started to assign different attacks (~200) to phases to achieve a consistent taxonomy for attacks

- Mitre also explains how to detect the attacks and how to protect against them (mitigation).

MITRE ATT&CK Matrix



Source: https://www.researchgate.net/figure/MITRE-ATT-CK-Kill-Chain-25_fig4_352479920

MITRE ATT&CK Matrix – Windows



Source: https://attack.mitre.org/matrices/enterprise/windows/